RANSOMWARE-ANGRIFF AUF COLLINS AEROSPACE

Security Incident Analyse: BER & Europäische Flughäfen

September 2025 – Januar 2026

Methodenkompetenz in der IT-Sicherheit

AGENDA

01 Überblick & Timeline

02 Collins Aerospace & MUSE-System

03 Angriffsvektor & Technische Details

04 MITRE ATT&CK Mapping

05 Threat Actors: Everest & HardBit

06 Auswirkungen auf BER & Europa

07 Datenexfiltration & Darknet-Leak

08 Supply-Chain & Konzentrationsrisiko

09 Rechtlicher Rahmen: NIS2, DSGVO, CRA

10 Lessons Learned & Empfehlungen

ANGRIFFSVERLAUF: SEPTEMBER BIS NOVEMBER 2025

AKT I – INFILTRATION

10. Sept.

Everest Group

Initial Access

Zugang via kompromittierte FTP-Credentials → `ftp.arinc.com` (vMUSE-Backend)

11. Sept.

Exfiltration

1,5 Mio. Datensätze gestohlen

Passagierdaten, Mitarbeiterdaten, Binaries, Logs & interne Systemdaten (50+ GB gesamt) — Zugang anschließend erkannt & blockiert

AKT II – ESKALATION

15.–18. Sept.

Verhandlung

Lösegeld-Ultimatum – abgelehnt

Kontaktaufnahme durch Everest — Collins verweigert Zahlung

Nacht 19./20. Sept.

HardBit Ransomware

MUSE-Systeme verschlüsselt

Core-Databases gesperrt — **europäischer Systemausfall** in den frühen Morgenstunden des 20. September

ANGRIFFSVERLAUF: SEPTEMBER BIS NOVEMBER 2025

AKT III – CHAOS & WENDE

20.–22. Sept.

Systemausfall

5 Flughäfen im manuellen Betrieb

BER, Heathrow, Brüssel, Dublin, Cork — Check-in & Boarding per Hand

23./24. Sept.

NCA

Festnahme – West Sussex, UK

NCA verhaftet Mann in seinen Vierzigern — Pressemitteilung am 24. September

29. Sept.

Recovery

Rollout Ersatzsystem

Schrittweise Normalisierung des Flugbetriebs

11. Nov.

Nachwirkung

23 GB Darknet-Leak

Everest veröffentlicht Binaries, Logs, interne Tools — Air Arabia-DB zum Verkauf für **$2 Mio.**

COLLINS AEROSPACE & MUSE: 170 FLUGHÄFEN AUF EINER PLATTFORM

COLLINS AEROSPACE (RTX CORP.)

- Tochter von RTX (ehem. Raytheon Technologies)
- US-Rüstungs- und Luftfahrtkonzern
- Systeme für ~170 Flughäfen weltweit
- Avionik, Interiors, Mission Systems

MUSE / VMUSE / CMUSE

- Multi-User System Environment (CUPPS)
- Gemeinsame Check-in & Boarding Plattform
- Airlines teilen Schalter, Kiosks, Gates
- Verbindung über ARINC AviNet VPN

⚠ Oracle GlassFish Server (ca. 2012)

Seit Jahren ungepacht; aktuelle Version: 7.0.25 (exakte Versionsnummer nicht unabhängig verifiziert)

⚠ Webmail-Login über HTTP

Keine Verschlüsselung der Anmeldedaten

⚠ FTP-Credentials nie rotiert

Kompromittiert durch RedLine Infostealer (2022)

ANGRIFFSVEKTOR: CREDENTIAL THEFT BIS RANSOMWARE-DEPLOYMENT

2022

Credential Theft

RedLine Infostealer infiziert Collins-Mitarbeiter-PC → FTP-Credentials (`aiscustomer`, `muse-insecure`) gestohlen

10. September 2025

Initial Access

Everest nutzt kompromittierte Credentials → Zugang zu `ftp.arinc.com` (vMUSE-Backend)

11. September 2025

Exfiltration

1,5 Mio. Passagierdaten, Mitarbeiterdaten, 50+ GB Netzwerk-Topologie exfiltriert

19. September 2025

Ransomware-Deployment

HardBit-Ransomware verschlüsselt Core-Databases → MUSE-Systeme fallen europaweit aus

DIE ANGRIFFSKETTE SYSTEMATISCH: MITRE ATT&CK

TA0001 Initial Access	T1078 Valid Accounts · T1199 Trusted Relationship (Supply Chain)
TA0002 Execution	T1204 User Execution (Malware über Infostealer erfordert Nutzerinteraktion)
TA0005 Defense Evasion	T1078 Valid Accounts (Legitime FTP-Credentials umgehen Erkennung)
TA0009 Collection	T1005 Data from Local System (Passagier-, Mitarbeiter-, Topologie-Daten)
TA0010 Exfiltration	T1048 Exfiltration Over Alternative Protocol (FTP-basierte Exfiltration über ftp.arinc.com)
TA0040 Impact	T1486 Data Encrypted for Impact (HardBit verschlüsselt MUSE Core-Databases)

THREAT ACTORS: EVEREST GROUP & HARDBIT RANSOMWARE

EVEREST GROUP

- Russischsprachig, aktiv seit 2020
- Hybrid: Ransomware + Initial Access Broker
- Doppelte Erpressung (Double Extortion)
- 105+ Opfer in 12 Monaten (Q4/2025)
- **Rolle hier: Datenexfiltration & IAB**

HARDBIT RANSOMWARE

- Erstmals gesehen: Oktober 2022
- Affiliate-/RaaS-Modell (jeder kann kaufen)
- Kein eigenes Portal – sehr simpel
- Verhandelt Lösegeld basierend auf Cyber-Versicherungspolice
- HardBit 4.0 deaktiviert Windows Defender aktiv (Registry, PowerShell)
- **Rolle hier: Ransomware-Deployment**

Dual-Incident-Szenario: Everest hat Verantwortung als IAB übernommen und behauptet, den Zugang an einen separaten HardBit-Deployer verkauft zu haben. (Protos Labs: „claim-based attribution" – kein öffentlich präsentierter kryptografischer Beweis)

SCHADENSAUSMASS: KENNZAHLEN DES VORFALLS

5	29+	994	10 Tage	600%
Betroffene Flughäfen	Gestrichene Flüge (Tag 1)	Kompromittierte Computer	Bis zur Normalisierung	Anstieg Cyberangriffe Luftfahrt

AUSWIRKUNGEN AUF FÜNF EUROPÄISCHE FLUGHÄFEN

Flughafen	Land	Auswirkung	Besonderheit
Berlin BER	DE	Check-in, Kiosks, Gepäck	Berlin-Marathon verschärfte Chaos
Heathrow	UK	Begrenzt (BA eigenes System)	Betroffen ab 20. Sept.
Brüssel	BE	Vollständig – nur manuell	Zuerst betroffen (19. Sept.); langsamste Recovery
Dublin	IE	T2 – Check-in, Gepäck	Server-Rebuild from scratch
Cork	IE	Check-in, Verspätungen	—

DATENEXFILTRATION & DARKNET-VERÖFFENTLICHUNG

1.533.900 Passagierdaten

- Frequent-Flyer-Details
- Reisedaten, Sitznummern
- Passagier-IDs

3.637 Mitarbeiterdaten

- Namen, Benutzernamen
- E-Mail-Adressen
- Login-Status, Audit-Metadaten

50+ GB Netzwerk-Topologie

- Workstation-Naming, Device-IDs
- Application-Stack-Fingerprints
- Netzwerk-Segmentierung

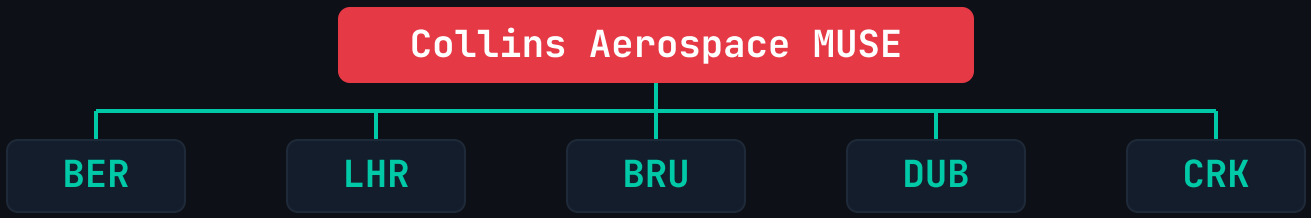
Darknet-Leak: 11. November 2025

23 GB veröffentlicht – Binaries, Diagnostik-Logs, interne Tools

Air Arabia-Datenbank zum Verkauf für **$2 Mio.**

```
passenger_data: 1.533.900 ▌
```

SUPPLY-CHAIN-RISIKO & KONZENTRATIONSRISIKO



KONZENTRATIONSRISIKO

- MUSE bedient ~170 Flughäfen weltweit
- Multi-Tenant-Plattform: Ein Ausfall = alle betroffen
- Vendor-Incidents: 37% aller Cyber-Claims (2024)
- Positiv: FMO (Münster) mit eigenem System blieb verschont

VERGLEICH: CROWDSTRIKE-VORFALL (07/2024)

- CrowdStrike: Fehlerhaftes Update → globaler Ausfall
- Collins: Gezielter Angriff → regionaler Ausfall
- **Gemeinsame Schwachstelle:** Single Points of Failure in kritischer Infrastruktur
- Beide: Effizienz → Fragilität

☠ DUAL-INCIDENT-SZENARIO: INITIAL ACCESS BROKER & RANSOMWARE-OPERATOR

AKTEUR 1: EVEREST (IAB)

PHASE: RECONNAISSANCE & EXFILTRATION

- 10. Sept.: Zugang über FTP-Credentials
- 11. Sept.: Datendiebstahl (1,5M+ Records)
- 15. Sept.: Lösegeld-Forderung an RTX
- 16.–18. Sept.: Verhandlungen scheitern

→

AKTEUR 2: RANSOMWARE-DEPLOYER

PHASE: DESTRUCTION / ENCRYPTION

- 19. Sept.: HardBit-Deployment
- Core-Databases verschlüsselt
- MUSE europaweit offline
- Reinfektionen bei Recovery-Versuchen

Typisch für modernes Ransomware-Ökosystem: Arbeitsteilung zwischen Initial Access Brokern (IAB) und Ransomware-Operatoren. Everest hat Verantwortung übernommen und behauptet, den Zugang verkauft zu haben; ein Affiliate deployete HardBit. **Beide profitieren.** (Laut Protos Labs noch „claim-based attribution")

RECHTLICHE IMPLIKATIONEN: NIS2, DSGVO & SEC-MELDEPFLICHTEN

NIS2-RICHTLINIE (EU)

- 24h Erstmeldung, 72h Detail-Report (Art. 23)
- Abschlussbericht innerhalb 1 Monat nach 72h-Meldung
- Essential Entities (KRITIS)
- Geschäftsführerhaftung

DSGVO / GDPR

- 72h Meldepflicht bei Data Breach
- Bußgelder bis 4% des Jahresumsatzes
- Betroffenenbenachrichtigung

SEC FILING (USA)

- RTX Form 8-K am 26. Sept. 2025
- 4 Werktage Meldepflicht
- Board-Level Verantwortung

CRA & EASA PART-IS

- Cyber Resilience Act: Meldepflicht für Severe Incidents an ENISA
- EASA Part-IS: Luftfahrt-spezifische Cybersecurity-Anforderungen

UK: Computer Misuse Act (Festnahme), NIS-Regulations, Cyber Security and Resilience Bill (im Gesetzgebungsverfahren seit Nov. 2025)

💡 LESSONS LEARNED & PRÄVENTIONSMASSNAHMEN

Drei Schwachstellen ermöglichten den Angriffserfolg – **alle waren vor dem Vorfall bekannt und behebbar.**

🔑 Infostealer-Fund 2022 → Credentials 3 Jahre nicht rotiert → **Initial Access**

01 Credential Hygiene

✓ MFA auf allen kritischen Systemen · regelmäßige Rotation · kontinuierliches Leak-Monitoring

🖴 Oracle GlassFish 3.1.2.9 (2012) in Produktion → bekannte CVE ungepacht → **RCE**

02 Patch Management

✓ Lifecycle-Richtlinien · Vulnerability-Scanning · gilt explizit auch für Drittsoftware

🖧 MUSE ohne vertragliche Sicherheitsstandards → schwächstes Glied → **Single Point of Failure**

03 Supply-Chain-Audits

✓ Pentest-Pflicht für Dienstleister · Redundanzanforderungen · KRITIS-konforme SLAs

KERNBEFUND

Technische Lücken bleiben ohne **organisatorische Verantwortung** dauerhaft offen – Zuständigkeiten, Budgets, Prozesse. Der Collins-Fall ist kein Ausreißer, sondern ein **strukturelles Muster kritischer Infrastruktur.**

WEITERE PRÄVENTIONSMASSNAHMEN

Netzwerk-Segmentierung

Kein implizites Vertrauen innerhalb des Perimeters

MUSE lief außerhalb des RTX-Kernnetzes – interne Segmentierung fehlte. Einmal im System war **Lateralbewegung bis zu den Core-Databases** möglich. Kritische Zonen mit explizit erlaubten Verbindungen, alles andere blockiert.

Incident Response

Supply-Chain-Szenarien explizit einplanen

Mehrfachreinfektionen zeigen: Containment war unvollständig. **IR-Pläne müssen Drittparteien einschließen** – koordinierte Kommunikation, isoliertes Wiederanlaufen, klare Zuständigkeitsketten.

Redundanz & Fallback

Graceful Degradation als Designprinzip

FMO: eigenes Backend verhinderte Totalausfall. **Architektonische Pflicht für KRITIS**, nicht nachträgliche Absicherung. „No one ever planned for a day when common use itself would need a backup." (Branchenexperte, Feb. 2026)

REGULATORISCHE VERANKERUNG

NIS2 Art. 21	Segmentierung (g) & Incident Response (b) als Cyber-Hygiene-Pflicht – **direkt bußgeldbewehrt**
DSGVO Art. 32	Mangelnde Segmentierung begründet **direkte Haftung** bei Datenschutzverletzungen
CRA ab 2027	Redundanzpflicht für digitale Produkte · ENISA-Meldepflicht ab **Sept. 2026**

ZUSAMMENFASSUNG

Der Ransomware-Angriff auf Collins Aerospace zeigt exemplarisch die Verwundbarkeit kritischer Infrastruktur durch Supply-Chain-Angriffe:

Technisch: Veraltete Infrastruktur (GlassFish 2012), nicht rotierte Credentials (seit 2022), fehlende Netzwerk-Segmentierung ermöglichen einen 'incredibly basic' Angriff mit verheerenden Folgen.

Organisatorisch: Single Point of Failure durch zentrale Multi-Tenant-Plattform. Dual-Incident-Szenario (IAB + Ransomware) als typisches Muster moderner Cyberkriminalität.

Rechtlich: NIS2, DSGVO, CRA und SEC-Meldepflichten greifen. §30 BSIG hätte Supply-Chain-Risikobewertung erzwungen. Geschäftsführerhaftung wird Realität.

Methodisch: MITRE ATT&CK ermöglicht strukturierte Analyse der Angriffskette von Initial Access (T1078) über Exfiltration (T1048) bis Impact (T1486).

QUELLEN

[1] RTX Corp. – SEC Filing Form 8-K, 26.09.2025

[2] ENISA – Offizielle Ransomware-Bestätigung, 22.09.2025

[3] Protos Labs – Deep Dive: Everest Group, 25.10.2025

[4] Cyberdaily.au – Passenger & Employee Data Compromised, 22.10.2025

[5] Lawfare – European Airports Ransomware Attack, 21.11.2025

[6] Taylor Wessing – NIS2 Implementation: Lessons Learnt, 25.09.2025

[7] Industrial Cyber – Cyberattack on a Software Product, 14.10.2025

[8] BlackFog – Ransomware on Collins Aerospace, 29.09.2025

[9] Resilience – Collins Aerospace Outage: Vendor Risk, 24.09.2025

[10] SecurityWeek – RTX Confirms Airport Services Hit, 25.09.2025

[11] Heise Online – Old Passwords & Delayed Response, 26.10.2025

[12] Part-IS.eu – Everest Ransomware Targets Collins Aerospace, 30.10.2025

[13] EP & Rat der EU – NIS-2-Richtlinie (EU) 2022/2555, Amtsbl. L 333, 2022

[14] EP & Rat der EU – Cyber Resilience Act (EU) 2024/2847, Amtsbl., 2024

[15] EP & Rat der EU – DSGVO (EU) 2016/679, Art. 32 & 33, Amtsbl. L 119, 2016

[16] EU-Kommission – EASA Part-IS, Del.VO (EU) 2022/1645 & DVO (EU) 2023/203

[17] Hudson Rock – Infostealer-Analyse: Collins Aerospace Credential Theft, 2022/2025

[18] BBC News – NCA Arrests Man in West Sussex Over Airport Cyberattack, 24.09.2025

[19] Wikipedia – Collins Aerospace Cyberattack (2025); Reihenfolge betroffener Flughäfen

[20] PMC / MDPI – Smart Airport Cybersecurity: Survey Study (Soussi et al.), 2018

[21] LinkedIn – A. Timajchi: „No one ever planned for a day when common use itself would need a backup", Feb. 2026